

Vulnerability assessment project

Automated Vulnerability Scanning Using Tenable Nessus Essentials

Tool: Tenable Nessus Essentials
Target System: Metasploitable 2
Environment: Kali Linux + Oracle VirtualBox
Scan Policy: Basic Network Scan

Field: Cybersecurity,
Vulnerability Management
Author: Ruslan Sokolov
Junior Security Analyst

October 2026

Table of contents

1 Laboratory Environment and Scope Description	3p.
1.1.Target System Context	3p.
1.2. Network Isolation of the Environment	3p.
1.3 Methodology and Tenable Nessus Configuration	3p.
2 Executive Summary of Findings	4p.
3 Detailed Analysis of Key Plugin Findings	6p.
3.1. Nessus Plugin Findings: SSL/TLS Cryptographic Issues	6p.
3.2. Critical OS-Level Findings: System Backdoors	7p.
4 Remediation Plan Based on Nessus Recommendations	9p.
Conclusion	9p.

1 LABORATORY ENVIRONMENT AND SCOPE DESCRIPTION

1.1. Target System Context

The target of the assessment was the Metasploitable 2 operating system (IP address: 10.0.2.4), deployed using an outdated Canonical Ubuntu Linux SEoL (8.04.x) distribution.

The system is intentionally configured with critical security misconfigurations, outdated versions of network services, and built-in backdoors. The primary objective of the project was to evaluate the effectiveness of the enterprise-grade Tenable Nessus vulnerability scanner in identifying both exposed and less apparent security weaknesses.

1.2. Network Isolation of the Environment

To safely deploy the assessment environment in the Oracle VirtualBox hypervisor, an isolated cyber laboratory environment was configured:

- **Network Mode:** NAT Network, subnet 10.0.2.0/24.
- **Scanning Host:** Kali Linux, hosting the Nessus scanner.
- **Host Security:** Port forwarding to the physical host/network was explicitly disabled. This isolated the vulnerable target from the real-world home network while maintaining internal network connectivity between Kali Linux and Metasploitable 2.

1.3 Methodology and Tenable Nessus Configuration

The security assessment was performed exclusively using the functionality provided by Tenable Nessus Essentials.

1. **Software Deployment:** The vulnerability scanner was deployed on the Kali Linux system.
2. **Scan Configuration:** The official Basic Network Scan template was selected and configured as the scanning policy.
3. **Data Processing and Risk Classification:** The identified vulnerabilities were automatically assessed using the Common Vulnerability Scoring System (CVSS) v3.0 risk-rating framework.

2 EXECUTIVE SUMMARY OF FINDINGS

Upon completion of the vulnerability scan, Nessus identified 72 vulnerability findings and 140 informational findings.

Within the Nessus interface, findings are categorized as Critical, High, Medium, Low, and Mixed. The Mixed category contains 20 findings and is not represented as a separate severity level in the CVSS severity distribution chart.

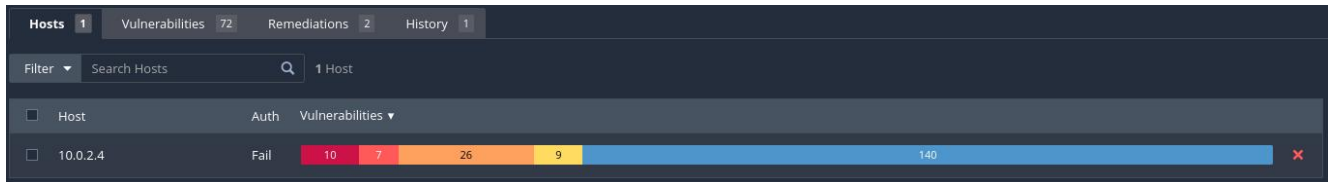


Fig. 1 — Overall scan summary



Fig. 2 — Vulnerability severity distribution

The scan identified a total of 72 vulnerability findings. The Nessus interface classified the findings into the following categories:

- **Critical:** 10
- **High:** 7
- **Medium:** 26
- **Mixed :** 20
- **Low:** 9
- **Informational:** 140

A significant portion of the critical findings was associated with outdated versions of network services, including Apache Tomcat and database services, as well as serious weaknesses in SSL/TLS transport-layer security.

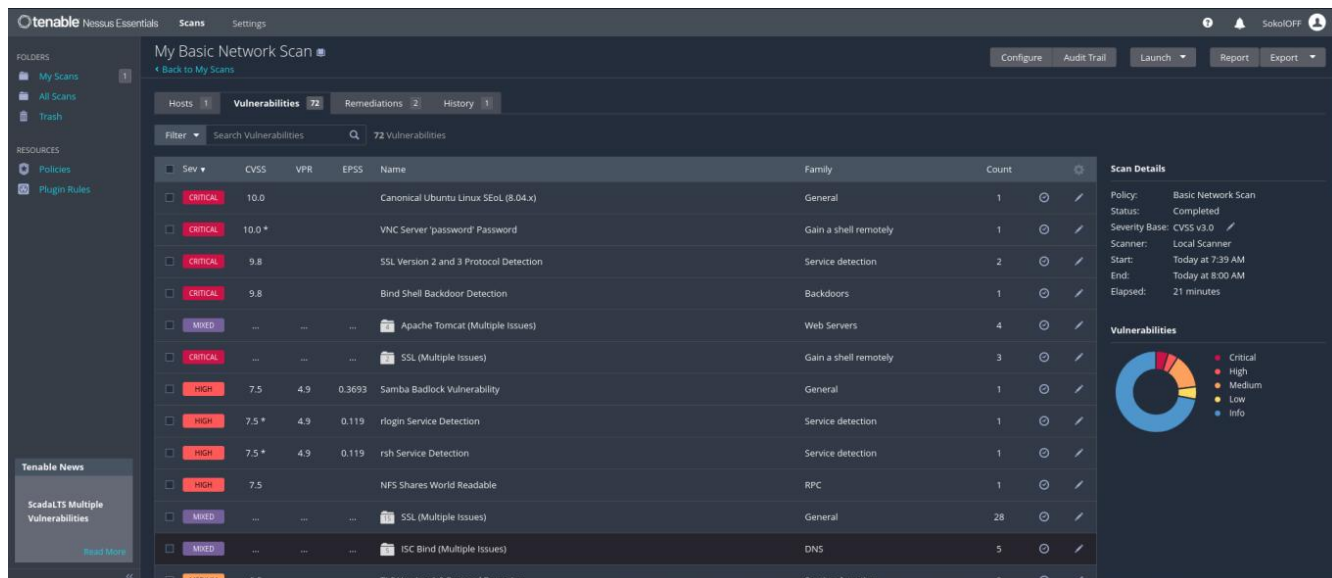


Fig. 3 — Overall vulnerability scan results

3 DETAILED ANALYSIS OF KEY PLUGIN FINDINGS

For a more detailed assessment, several critical vulnerability findings were selected for further analysis.

3.1. SSL Version 2 and 3 Protocol Detection.

The screenshot displays the Tenable Nessus Essentials interface. The main panel shows the 'Vulnerabilities' tab for a scan titled 'My Basic Network Scan / Plugin #20007'. The vulnerability is 'SSL Version 2 and 3 Protocol Detection', marked as 'CRITICAL'. The description explains that the remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0, which are affected by several cryptographic flaws. It lists two specific flaws: an insecure padding scheme with CBC ciphers and an insecure session renegotiation and resumption schemes. It also mentions that an attacker can exploit these flaws to conduct man-in-the-middle attacks or to decrypt communications. The solution section advises consulting the application's documentation to disable SSL 2.0 and 3.0, and using TLS 1.2 (with approved cipher suites) or higher instead. The 'Plugin Details' sidebar on the right shows the severity as 'Critical', ID as '20007', version as '1.35', type as 'remote', family as 'Service detection', published date as 'October 12, 2005', and modified date as 'April 13, 2026'. The 'Risk Information' section shows a 'Risk Factor: Critical' and a 'CVSS v3.0 Base Score: 9.8'. The 'Vulnerability Information' section shows 'In the news: true'.

Fig. 4 — Detailed analysis of the SSL/TLS cryptographic security issue

The screenshot displays the 'Output' section of the Tenable Nessus Essentials interface. It shows two sections of output, one for 'Port 25 / tcp / smtp' and one for 'Port 5432 / tcp / postgresql'. Both sections show that SSLv2 is enabled and the server supports at least one cipher. The first section also shows a table of 'Low Strength Ciphers (<= 64-bit key)' with columns for Name, Code, KEX, Auth, Encryption, and MAC. The table lists two ciphers: 'EXP-RS2-CBC-MD5' and 'EXP-RS4-MD5'. The second section shows that SSLv3 is enabled and the server supports at least one cipher. It also shows a table of 'Medium Strength Ciphers (> 64-bit and < 112-bit key, or 3DES)' with columns for Name, Code, KEX, Auth, Encryption, and MAC. The table lists two ciphers: 'EXP-RS2-CBC-MD5' and 'EXP-RS4-MD5'.

Fig. 5 — Detailed analysis of the SSL/TLS cryptographic security issue

- **Vulnerability Name:** SSL Version 2 and 3 Protocol Detection
- **Plugin ID:** 20007
- **Affected Services / Ports:** 25 / tcp / smtp , 5432 / tcp / postgresql
- **Risk Rating:** CVSS v3.0 Base Score: 9.8 (Critical)

Nessus Finding Description:

The plugin detected that remote services accept network connections secured using the deprecated SSLv2 and SSLv3 protocols.

The scanner also identified support for cryptographically weak export-grade cipher suites, including:

EXP-RC2-CBC-MD5

EXP-RC4-MD5

with Low/Medium Strength Ciphers $\leq$ 64-bit keys.

The continued support of these obsolete protocols and weak cipher suites may expose encrypted communications to downgrade and cryptographic attacks, including attacks associated with the POODLE vulnerability class.

Security / Business Impact:

Under appropriate network conditions, an attacker positioned on the local network could potentially perform a Man-in-the-Middle (MitM) attack and attempt to force a downgrade to a weaker cryptographic protocol, potentially enabling interception or analysis of protected traffic.

The practical impact depends on the specific service configuration, network position of the attacker, and other conditions required for successful exploitation.

Nessus Remediation:

Review the configuration of the affected SMTP and PostgreSQL services.

Completely disable SSLv2 and SSLv3 support.

Restrict encrypted connections to modern, secure protocol versions such as TLS 1.2 and TLS 1.3, using strong cipher suites appropriate for the deployed service and operating system.

3.2. Bind Shell Backdoor Detection

The screenshot displays the Nessus Essentials interface for a finding titled "Bind Shell Backdoor Detection" (Plugin #51988). The interface is divided into several sections:

- Left Sidebar:** Contains navigation links for "My Scans", "All Scans", "Trash", "Policies", and "Plugin Rules".
- Top Bar:** Shows the scan name "My Basic Network Scan / Plugin #51988" and buttons for "Configure", "Audit Trail", "Launch", "Report", and "Export".
- Findings List:** A table with columns "Hosts", "Vulnerabilities", "Remediations", and "History". The "Vulnerabilities" column shows a count of 72.
- Findings Detail:** The selected finding is "Bind Shell Backdoor Detection", marked as "CRITICAL".
 - Description:** "A shell is listening on the remote port without any authentication being required. An attacker may use it by connecting to the remote port and sending commands directly."
 - Solution:** "Verify if the remote host has been compromised, and reinstall the system if necessary."
 - Output:** A text box showing the command "id" being executed, resulting in a root shell for the user "metasploit".
 - Plugin Details:** A table with fields: Severity (Critical), ID (51988), Version (1.10), Type (remote), Family (Backdoors), Published (February 15, 2011), and Modified (April 11, 2022).
 - Risk Information:** A table with fields: Risk Factor (Critical), CVSS v3.0 Base Score (9.8), CVSS v3.0 Vector (CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H), CVSS v2.0 Base Score (10.0), and CVSS v2.0 Vector (CVSS2#AV:N/AC:L/Au:N/C:C/C:C/A:C).
- Bottom Section:** A table showing the port and host details for the finding.

Port	Hosts
1524/tcp /bind shell	10.0.2.4

Fig. 6 — Detailed analysis of the bind shell backdoor finding

- **Vulnerability Name:** Bind Shell Backdoor Detection
- **Plugin ID:** 51988
- **Affected Service / Port:** 1524 / tcp / bind_shell
- **Risk Rating: CVSS v3.0 Base Score: 9.8** (Critical)

Nessus Finding Description:

The specialized backdoor detection plugin identified a command shell listening on TCP port 1524 that accepts connections without requiring authentication.

Technical Evidence — Scanner Output:

Nessus successfully established a connection to the port and issued the id command.

The Metasploitable 2 target returned the following output, confirming execution with root-level privileges:

```
root@metasploitable:/# id
uid=0(root) gid=0(root) groups=0(root)
```

This demonstrates that the exposed service provides a remote command shell operating with root privileges.

Security / Business Impact :

The impact is critical because an unauthenticated remote attacker with network access to the service could potentially execute arbitrary commands on the target system with root-level privileges.

Such access could result in complete system compromise, unauthorized modification or deletion of data, installation of additional malicious software, and compromise of other systems reachable from the target.

4 REMEDIATION PLAN BASED ON NESSUS RECOMMENDATIONS

To address the identified security risks, the system owner should implement the remediation actions provided in the Solution sections of the Nessus findings.

PostgreSQL Security Configuration:

Review and harden the PostgreSQL SSL/TLS configuration in postgresql.conf by disabling deprecated protocols and weak cipher suites.

Example configuration:

```
ssl = on
ssl_ciphers = 'HIGH:!aNULL:!MD5:!3DES'
ssl_protocols = 'TLSv1.2, TLSv1.3'
```

Emergency Port Restriction:

Configure the internal host firewall, such as iptables, or an appropriate VirtualBox network control to restrict access to the following services: TCP/1524 exposed bind shell/backdoor, TCP/5900 insecure VNC service configured with the default password password

The preferred remediation is to disable unnecessary services entirely rather than relying solely on network-level filtering.

Software Lifecycle Management:

The Canonical Ubuntu Linux SEoL finding indicates that the operating system has reached End of Life (EoL) and is no longer receiving standard security updates.

A planned migration of all services to a currently supported operating system should therefore be performed.

CONCLUSION

During this project, the Tenable Nessus Essentials vulnerability assessment platform was successfully deployed and used to perform an automated security assessment of a Metasploitable 2 target system.

The practical assessment demonstrated the importance of regular automated vulnerability scanning. During a single scan cycle, Nessus identified 72 vulnerability findings and 140 informational findings, categorized the identified issues according to severity, and provided remediation guidance for the detected vulnerabilities.

The assessment also demonstrated how vulnerability management tools can assist security teams in identifying outdated cryptographic protocols, exposed services, authentication weaknesses, backdoors, and unsupported software platforms.

The results highlight the importance of maintaining supported software versions, minimizing exposed network services, enforcing modern cryptographic protocols, and continuously validating the security posture of systems through periodic vulnerability assessments.